

FRAUD360

Infrastructure Requirements

Hosting Fraud360 on a private cloud with VM infrastructure

Version 1.1 · 2 October 2026

Finverge · Confidential — for the customer's infrastructure and security teams

Document control

Item	Detail
Document	Fraud360 — Infrastructure Requirements (private cloud, VM-based)
Version	1.1 — 2 October 2026 (supersedes 1.0)
Companion	Fraud360 — Deployment Instructions v1.1 (the step-by-step build and release runbook)
Platform baseline	Fraud360 as described in BRD v1.9, FSD v1.6, HLD v1.8 (40 of 42 RBI-2016 EWS signals fully covered, 2 partial, 0 uncovered)
Audience	Customer infrastructure, network, database, security and DR teams; Finverge delivery engineers
Changes in 1.1	Roles and permissions are now database-driven. Every service that authorises a request reads the tenant's role rows from tenant-service, so tenant-service is on the authorisation path of the whole platform (§4.1, §7.3, §10). New security row and two new known gaps (§9, §14).
Status	Baseline for review. Sizing is an engineering estimate, not load-test evidence — see §2.2

Contents

1. Purpose and scope.....	4
1.1 What is being hosted	4
1.2 What is explicitly out of scope	4
2. Basis of this document.....	5
2.1 Assumptions	5
2.2 How far the sizing numbers can be trusted	5
3. Reference architecture on VMs.....	6
3.1 Design decisions that drive the layout.....	6
4. Workload inventory	7
4.1 Services	7
4.2 Batch workers and scheduled jobs	7
4.3 State that lives outside the database	8
5. Virtual machine inventory and sizing	9
5.1 Production profile (per site)	9
5.2 Pilot / UAT profile	9
5.3 Sizing rules	9
5.4 Unicorn processes per service	10
5.5 PostgreSQL requirements	10
5.6 Optional components	11
6. Software requirements.....	12
6.1 Operating system and platform packages	12
6.2 Python dependencies (pinned in `requirements.txt`)	12
7. Network requirements	13

7.1 Zones and addressing	13
7.2 DNS names and certificates	13
7.3 Firewall rule set	13
7.4 Outbound access that needs a decision	14
8. Storage, backup and disaster recovery.....	15
8.1 Storage requirements.....	15
8.2 Retention	15
8.3 Recovery objectives	15
8.4 Disaster-recovery site	15
9. Security and compliance requirements.....	16
10. Availability design and failure behaviour	17
10.1 Configuration coherence across replicas.....	17
11. Observability and operations.....	18
12. Environments.....	19
13. Prerequisites the customer provides.....	20
14. Known gaps and risks.....	21
Appendix A — If the React console is hosted later.....	22
Appendix B — Decisions requested from the customer	22

1. Purpose and scope

This document states what a customer must provide, in compute, storage, network, platform software, security controls and operating services, to host Fraud360 on its own private cloud using virtual machines. It is written so that an infrastructure team can raise the requests (VMs, VLANs, firewall rules, certificates, backup policy) without needing to read the application design documents.

It covers the production environment, a disaster-recovery site, and a smaller pilot/UAT profile. It does not cover how to install the software — that is the Deployment Instructions document — and it does not restate application functionality, which is in the BRD, FSD and HLD.

1.1 What is being hosted

Fraud360 is a multi-tenant fraud and early-warning platform for banks and NBFCs, delivered as nine Python (FastAPI) services (plus an optional ISO 8583 gateway) built from one code base and one dependency set, plus a set of scheduled and continuously running batch workers, backed by a single PostgreSQL database. It works in three lanes:

Lane	Purpose	Latency class	Where it runs
A — inline	Approve / challenge / decline a payment in the authorisation window (POST / decide ; optional ISO 8583 front door)	50–150 ms budget by rail	Dedicated decision VMs
B — near-real-time	CBS and payment events scored by detection workers; alerts, cases, EWS rules	Seconds (NFR-01: under 5 s receipt-to-alert)	App VMs (ingest API) + worker VMs (detection)
C — periodic review	Borrower financial-statement review: PDF parse, OCR fallback, signal scoring	Minutes; batch	App VMs (upload API) + worker VMs (parse and score)

1.2 What is explicitly out of scope

- **Kubernetes and managed cloud services.** This is a VM design. The code base also runs in containers (a Dockerfile exists), but no container platform is assumed or required here.
- **The React console in `frontend/`.** The console the platform serves today is the static single-page application that the gateway ships and serves itself; it has no build step. The React console is a separate migration still in progress and is not part of the baseline footprint (see Appendix A for the extra step if it is later hosted).
- **The demo identity provider** (**services/demo_idp**) and demo seed scripts. They are for demonstrations and must not be deployed to production.
- **Customer systems** the platform integrates with (core banking, switches, IdP, SIEM). Only the interfaces are listed.

2. Basis of this document

2.1 Assumptions

These assumptions shape every number below. Where the customer's reality differs, the affected sections are named so they can be revised rather than the whole document redone.

#	Assumption	Affects
A1	Linux VMs on any enterprise hypervisor (VMware vSphere, KVM/OpenStack, Hyper-V, Nutanix AHV). Nothing in the design is hypervisor-specific.	§5, §8
A2	Operating system is RHEL 9 or a rebuild (Rocky / Alma 9), or Ubuntu Server 22.04/24.04 LTS. 64-bit x86. The Deployment Instructions use RHEL-family commands and note Ubuntu differences.	§6
A3	No Kubernetes. Services run as systemd units from a Python 3.12 virtual environment, deployed as immutable release directories.	§4, §6
A4	PostgreSQL is self-managed on dedicated VMs (the HLD assumed a managed service; a private cloud has none). One primary, one synchronous standby, automated failover.	§5.5, §10
A5	One Indian primary site and one Indian DR site. RBI data localisation (BRD REG-07 / BR-714) requires every component and every backup to remain in India.	§8
A6	The customer already runs enterprise services: DNS, NTP, an internal PKI, an SMTP relay, a SIEM, a backup platform, and a secrets vault or HSM. Fraud360 consumes them; it does not ship its own.	§7, §9, §13
A7	Outbound internet access is restricted. Anything that needs it goes through an allow-listed proxy, and each such need is listed in §7.4.	§7
A8	A "tenant" is a bank or NBFC entity. One installation can serve many tenants (logical isolation, shared database). A customer that needs physical isolation between entities deploys one installation per entity.	§5, §14
A9	Pilot and UAT environments are the same software on a smaller footprint without high availability.	§12
A10	Mid-sized installation, as in HLD §"Cloud infrastructure required": sizing basis is a peak of a few hundred transactions per second across all tenants, 12 months of hot data.	§5

2.2 How far the sizing numbers can be trusted

Read this before quoting any figure

The BRD records NFR-02 (ingestion throughput), NFR-01 (detection latency) and NFR-03 (dashboard response) as **unvalidated**, and BR-909 (capacity evidence) as pending. The only measured figure is a single detection worker sustaining about **200 transactions per second at a p99 of 2.65 s**, on development hardware, with the run refusing to call itself sustained if the backlog climbs. Multi-worker scaling and a production-class database have not been measured. Every VM size, worker count and storage figure in §5 is therefore an engineering estimate with stated reasoning. Acceptance of the environment must include the load test in the Deployment Instructions (§15.1), and the figures here should be revised against its result.

The repository includes the load generator for this purpose (`scripts/loadtest.py`, e.g. `--rate 200 --duration 60`). It measures receipt-to-score latency and reports whether the queue drained, so a run that falls behind is reported as such.

3. Reference architecture on VMs

The platform is split into five zones. Each zone is a separate VLAN or security group with a firewall between it and the next; the rule set is in §7.3.

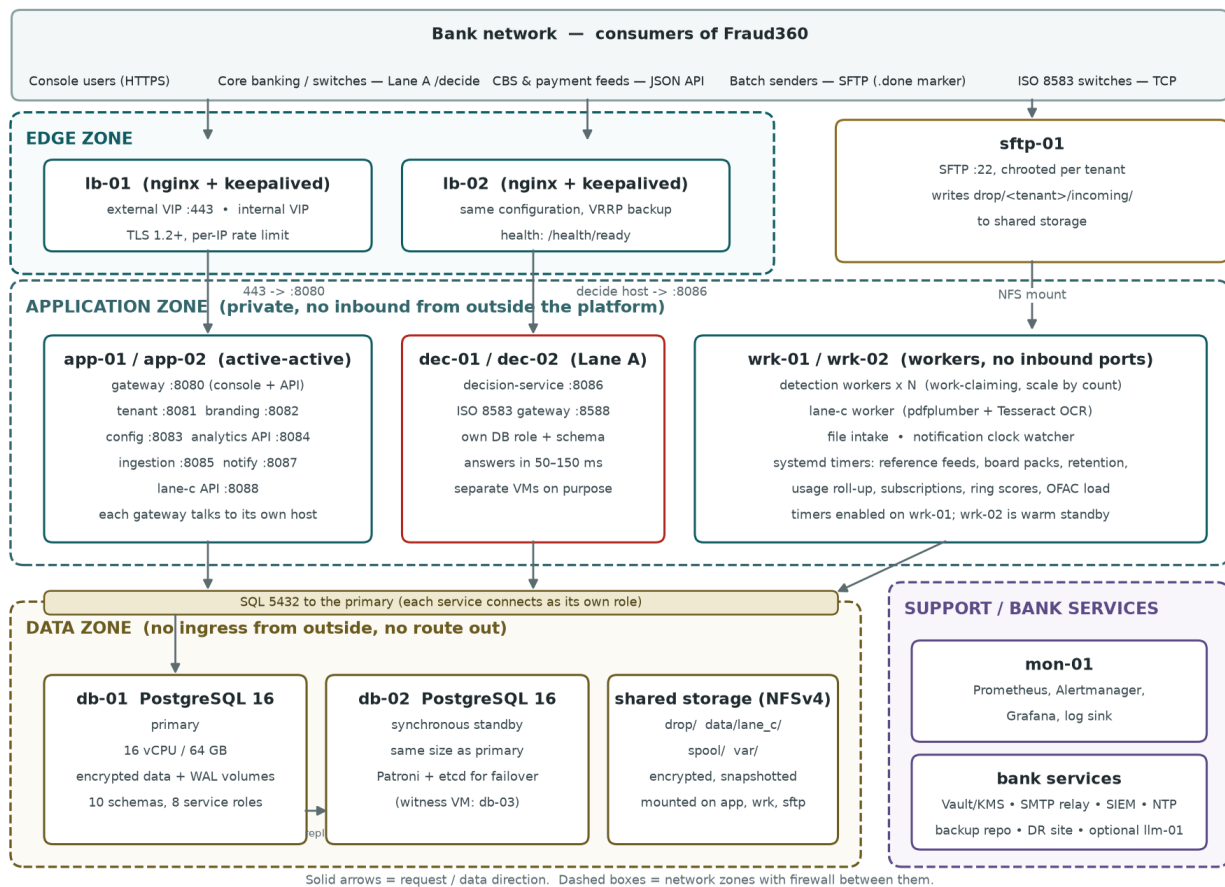


Figure 1 — Production topology, one site. DR is a reduced copy of the same layout (§8.4).

3.1 Design decisions that drive the layout

Decision	Reason
Lane A on its own VMs	The inline path sits in the payment authorisation window and has a stricter availability class than the console. It connects as its own database role, owns its own schema and is deliberately not proxied by the gateway (“the payment path ... must not inherit the console’s hop”). Co-locating it with analytics queries would let an expensive console query steal CPU from a 50–150 ms decision.
Each app VM is self-contained	Each app VM runs the gateway and every console-facing service, and the gateway on that VM calls the services on the same VM. The gateway’s readiness probe checks its upstreams, so the load balancer removes a VM whose local service has failed. No service-discovery layer is needed.
Workers have no inbound ports	Detection, Lane C scoring, file intake and the notification clock watcher pull work; nothing connects to them. That removes them from the attack surface and from the load balancer.
Detection workers scale by count	Work is claimed with FOR UPDATE SKIP LOCKED , so several copies, on one VM or many, take different slices of the queue and never duplicate work.
No message bus, no Redis	Ingestion writes a queue table and analytics consumes it; the shared configuration-generation counter is a one-row table. Fewer components to run, patch and certify. The queue is the seam a bus would later replace.
One shared database, ten schemas, eight roles	Each service connects as a role that can reach only its own schema, so isolation is enforced by PostgreSQL rather than by convention.

Decision	Reason
Shared file storage for three small directories	Statement PDFs (Lane C), SFTP batch drops and report pool are plain files that two different VM types must both see. A network file system keeps that simple; see §4.3.

4. Workload inventory

4.1 Services

One codebase, one dependency set. Each service is a uvicorn process started with its own module path.

Service	Port	DB role → schemas	Runs on	Notes
gateway	8080	none	app	TLS-terminated behind the LB. Serves the console static files, verifies JWTs, proxies <code>/api/*</code> , per-caller token bucket (20 req/s, burst 40 by default).
tenant-service	8081	svc_tenant → tenant, platform	app	Tenants, users, MFA, sessions, SSO (OIDC/SAML), machine-credential tokens (<code>/machine/token</code>). Also the source of every other service's role lookups (<code>GET /tenants/internal/{id}/roles</code>), so it is on the authorisation path of the whole platform.
branding-service	8082	svc_branding → branding, platform	app	White-label theming.
config-service	8083	svc_config → config, platform	app	Rules, thresholds, entity types; bumps the shared config-generation counter.
analytics-service	8084	svc_analytics → analytics, cases, ingestion, platform	app	Dashboards, cases, filings, reference feeds, AI-insights proxy. Loads NumPy, scikit-learn; heaviest API process.
ingestion-service	8085	svc_ingestion → ingestion, platform	app	JSON intake of transactions and CBS events; claim/ack API used by detection workers (X-Internal-Key).
notification-service	8087	svc_notify → notify, platform	app	Delivery over each tenant's own SMTP relay or webhook; inbox.
lane-c-service	8088	svc_lanec → lane_c, platform	app	Statement upload (stores PDFs by SHA-256), project appraisal/progress, manual findings.
decision-service	8086	svc_decision → decision, platform	dec	Lane A <code>POST /decide</code> . Called directly by the bank's switch/core with a machine token, not through the gateway.
iso8583-gateway	8588 (TCP) + HTTP health	none	dec (optional)	TCP listener that maps ISO 8583 authorisations onto <code>/decide</code> . Proposal-stage component; deploy only if the customer's switch cannot speak JSON. Needs an explicit fail-open/closed decision (§14).

4.2 Batch workers and scheduled jobs

All run from the repository root with `PYTHONPATH` set, as systemd services (continuous) or timers (scheduled). The database role is chosen by the schemas a job touches; jobs that read the tenant register alongside other schemas need the owner role, which is why the owner credential exists on worker VMs and nowhere else outside the DB tier.

Job	Mode / cadence	Instances	Runs as
<code>run_detection.py --loop 30</code>	Continuous; claims queued transactions and scores them	N across worker VMs	svc_analytics

Job	Mode / cadence	Instances	Runs as
<code>run_lane_c.py --loop 300</code>	Continuous; parse, OCR, score pending statements	1 per worker VM	svc_lanec
<code>run_file_intake.py --once</code>	Every minute; reads <code>drop/<tenant>/incoming/*.done</code>	1 (wrk-01)	svc_ingestion
<code>run_notifications.py --loop 300</code>	Continuous; derives due/overdue conditions from state	1 (wrk-01)	owner role (spans several schemas)
<code>run_reference_fetch.py --commit</code>	Daily; refresh tenant reference lists (digest-checked)	1 (wrk-01)	svc_analytics
<code>run_lane_c_reference_fetch.py --commit</code>	Daily; Lane C feeds (MCA ROC, rating actions)	1 (wrk-01)	svc_lanec
<code>run_board_pack.py --commit</code>	Daily; drafts board/ACB packs for closed periods	1 (wrk-01)	svc_analytics
<code>run_subscriptions.py --once</code>	Hourly; due report subscriptions	1 (wrk-01)	owner role
<code>run_usage_rollup.py</code>	Daily, just after midnight; finalises yesterday	1 (wrk-01)	owner role
<code>run_retention.py</code>	Weekly dry run to the journal; <code>--commit</code> only by an approved change (BR-713)	1 (wrk-01)	owner role
<code>refresh_ring_scores.py</code>	Per model cadence; GNN fraud-ring scoring (CPU PyTorch)	1 (wrk-01)	owner role
<code>load_ofac_sdn.py</code>	Daily; full replace of the OFAC SDN list	1 (wrk-01)	svc_analytics
<code>seal_secrets.py --commit</code>	Once after upgrades that add sealed columns; idempotent	manual	owner role
<code>alembic upgrade head</code>	Every release, before services restart	manual / pipeline	owner role

How the role column was derived

Roles are assigned from the schemas each script reads or writes, not from a documented table in the code base. The Deployment Instructions include a smoke run of every job under its stated role during acceptance, so a wrong assignment surfaces as a permission error before go-live.

4.3 State that lives outside the database

Path (default)	Written by	Read by	Needs shared storage?
<code>data/lane_c_statements/<tenant>/ (set LANE_C_STORAGE_DIR)</code>	lane-c API (app VMs)	Lane C worker (wrk VMs)	Yes — upload and parse happen on different VM types
<code>drop/<tenant>/ {incoming,archive,failed}/ (set INGEST_DROP_ROOT)</code>	SFTP server (sftp-01)	file-intake worker (wrk-01)	Yes
<code>spool/ (set REPORT_SPOOL_DIR)</code>	subscription runner (wrk-01)	humans / downstream pick-up	Yes, if pick-up is from another host
<code>var/notifications/</code>	notification-service (spool driver)	operators	Local is acceptable; spool driver is a no-relay fallback
<code>var/models/*.joblib</code>	training scripts (offline)	analytics API, workers	Yes (read-only on consumers) or copy at release

Documents and case evidence are stored **in the database**, not on disk, so database storage grows with evidence as well as with transactions.

5. Virtual machine inventory and sizing

5.1 Production profile (per site)

vCPU and memory are reserved allocations, not burst; do not overcommit CPU on the database, decision or worker VMs. Disks are thick or otherwise guaranteed-latency volumes; the database datastore must be low-latency SSD or NVMe-backed.

VM	Qty	vCPU	RAM	Disks	Role
lb-01, lb-02	2	2	4 GB	40 GB OS	HAProxy + keepalived (VRRP). External VIP: 443 to the gateway pool, host-routed <i>/decide</i> to the decision pool, TCP 8583 pass-through if ISO 8583 is used. Internal VIP for service APIs. Active health checks on <i>/health/ready</i> .
app-01, app-02	2	8	16 GB	100 GB OS + app	Gateway, tenant, branding, config, analytics API, ingestion, notification and lane-c API. Active-active.
dec-01, dec-02	2	4	8 GB	60 GB OS + app	decision-service; ISO 8583 gateway if in scope. N+1 for the inline path.
wrk-01, wrk-02	2	8	32 GB	200 GB OS + app + scratch	Detection workers, Lane C worker (Tesseract OCR), file intake, notifier, scheduled jobs. wrk-01 carries the timers; wrk-02 is warm.
db-01, db-02	2	16	64 GB	50 GB OS; 1 TB data; 200 GB WAL; 300 GB local backup spool	PostgreSQL 16 primary and synchronous standby, same spec. HLD basis: 16 vCPU / 64 GB class primary.
db-03	1	2	4 GB	40 GB OS	Consensus witness (etcd) so automatic failover cannot split-brain. Not a data node.
sftp-01	1	2	4 GB	40 GB OS	SFTP landing zone, chrooted per tenant. Data directory is on shared storage. Cold standby from snapshot.
mon-01	1	4	16 GB	50 GB OS; 500 GB metrics + logs	Prometheus, Alertmanager, Grafana, log sink (or forwarders to the bank SIEM).
Shared storage	—	—	—	1 TB usable, NFSv4, encrypted, snapshotted	Existing NAS, or a small dedicated NFS VM. Holds Lane C PDFs, SFTP drop, spool.
Total (13 VMs)		84	272 GB	~5.5 TB incl. NAS	Plus optional <i>11m-01</i> (\$5.6).

5.2 Pilot / UAT profile

For a single-tenant pilot, UAT or an acceptance rehearsal. No high availability; the intent is functional and integration testing, plus a load test of the detection path.

VM	Qty	vCPU	RAM	Disks	Role
fx-app-01	1	8	32 GB	200 GB	HAProxy, every service, Lane A, workers, SFTP, local file storage, Tesseract.
fx-db-01	1	8	32 GB	50 GB OS; 300 GB data; 50 GB WAL	PostgreSQL 16, single node, nightly dump + WAL archive to a bank share.
Total	2	16	64 GB	~600 GB	Self-signed or internal-CA certificate acceptable.

5.3 Sizing rules

Scale by count of identical VMs or processes, not by resizing, except the database.

Driver	Rule	Basis
Detection workers	$\text{workers} = \text{ceil}(\text{peak tps} \div 150) + 1$. Each worker is one process and one core; 150 is the measured 200 tps derated by 25% for headroom. 100 tps → 2, 300 → 3, 600 → 5, 1,000 → 8.	Measured single-worker figure; scaling beyond one worker is unmeasured (\$2.2).
wrk VM count	One wrk VM carries about 4 detection workers plus the other jobs. Add a wrk VM per four workers.	8 vCPU, workers + Lane C + OCR bursts.
app VMs	Two minimum. Add an app VM when p95 gateway latency or CPU on the analytics API approaches 70% at peak.	Console and API load is query-driven, not tps-driven.
dec VMs	Two minimum (N+1). Size from the Lane A inline rate at peak; the per-VM /decide rate is not yet measured and must come from the BR-909 load test.	Open item — do not promise a Lane A rate before measuring.
Database	Above roughly 500 sustained tps, benchmark the database before adding workers: each transaction writes a raw row, facts, features and scores. Plan for 32 vCPU / 128 GB and NVMe at that point.	Engineering estimate.
Connections	$\text{max_connections} = 500$ as a start. Worst case each service process holds 15 connections (SQLAlchemy default pool of 5 plus 10 overflow); roughly 30–35 processes across the estate gives a theoretical ceiling near 500, far above normal use.	Derived from the engine defaults; confirm in monitoring.

Why there is no connection pooler

PgBouncer in transaction mode is the usual answer to connection counts, but each Fraud360 service pins its `search_path` through a connection startup option, and its roles carry a role-level `search_path`; a pooler that multiplexes sessions would need to be configured to honour both. The design therefore sizes `max_connections` instead. Revisit only if monitoring shows connection pressure.

5.4 Uvicorn processes per service

The tested topology is **one uvicorn process per service per VM**, as in the local runner and the scaled compose overlay. Scale out by adding VMs. If an operator chooses `--workers N` instead, each worker process counts as a replica: `APP_REPLICAS` must be set to the true total, in-process rate limits multiply by the replica count (the gateway limiter is per process by design and is a safety valve, not a billing control), and the load test must be repeated.

5.5 PostgreSQL requirements

Item	Requirement
Version	PostgreSQL 16 (the compose file and HLD use 16). 15 is acceptable; do not go below 14.
Topology	Primary + synchronous standby in the same site (zero data loss on a local failure) + asynchronous standby at the DR site. Patroni with a three-member etcd consensus (db-01, db-02, db-03) and a virtual IP that follows the leader.
Storage	Data and WAL on separate volumes. Both encrypted at the volume layer (LUKS or hypervisor/datastore encryption) — BRD BR-712 requires this as a deployment control; the application seals only individual secrets.
Backups	pgBackRest: full weekly, differential daily, continuous WAL archiving for point-in-time recovery, repository in a separate failure domain and replicated to DR. Meets the BRD target of RPO 15 minutes; a synchronous standby brings local RPO to zero.
Key settings (start here)	<code>shared_buffers</code> 16 GB; <code>effective_cache_size</code> 44 GB; <code>work_mem</code> 32 MB; <code>maintenance_work_mem</code> 2 GB; <code>wal_level</code> replica; <code>max_wal_size</code> 16 GB; <code>checkpoint_timeout</code> 15 min; <code>random_page_cost</code> 1.1; <code>max_connections</code> 500; <code>synchronous_commit</code> on; <code>archive_mode</code> on.

Item	Requirement
Extensions	None beyond core. <code>pg_stat_statements</code> recommended for diagnosis.
Accounts	Owner role <code>cp</code> (DDL, migrations, retention and the cross-schema batch jobs); eight service roles created by <code>scripts/provision_db_roles.py</code> ; a separate DBA/superuser account kept off all application hosts.
Growth planning	Planning figure of 3–4 KB per transaction all-in (raw row, fact, features, scores, indexes). 1 million transactions per day is about 1.1–1.5 TB a year before case evidence and documents. This figure is an estimate to be replaced by the measured row cost from the load test.

5.6 Optional components

Component	When needed	Spec	Notes
llm-01 (local LLM host)	Only if a tenant enables narrative polish (<code>NARRATIVE_POLISH_ENABLED</code>), the Lane C qualitative red-flag read (<code>LANE_C_LLM_ENABLED</code> , RBI #38/#39) or AI Insights	GPU with 24 GB VRAM preferred; CPU-only works but is slow. 16 vCPU / 48 GB RAM / 200 GB disk (model weights)	Ollama-compatible endpoint inside the data-residency boundary. All three features are off by default ; nothing leaves the customer's infrastructure. Do not provision it unless the customer opts in.
iso8583 listener	Switch cannot speak JSON	Runs on the dec VMs	Needs the machine credential (<code>ISO8583_CLIENT_ID/SECRET</code>) and an explicit <code>ISO8583_FAIL_OPEN</code> decision.
React console host	If the React console replaces the shipped SPA	Static files on the lb VMs	Appendix A.

6. Software requirements

6.1 Operating system and platform packages

Component	Requirement	Where
OS	RHEL 9 / Rocky 9 / Alma 9, or Ubuntu 22.04/24.04 LTS; CIS Level 1 baseline; SELinux enforcing (RHEL family)	All VMs
Python	3.12 (the code base targets <code>python:3.12-slim</code>)	app, dec, wrk
Build dependencies	<code>gcc</code> , <code>python3.12-devel</code> , <code>libxml2-devel</code> , <code>libxslt-devel</code> (lxml / signxml); wheels preferred from an internal mirror	Build host only
Tesseract OCR	<code>tesseract-ocr</code> binary and language data (English at minimum; add scripts in use) — the Python package is only a binding	wrk VMs
PostgreSQL	16 server and client; Patroni, etcd, pgBackRest; <code>postgresql16-contrib</code>	db VMs; client on build/admin host
HAProxy	2.4 or later (RHEL 9 AppStream): active HTTP health checks, TLS termination, TCP mode for ISO 8583. Open-source nginx lacks active health checks, which the readiness design relies on	lb VMs
keepalived	VRRP for the load-balancer VIPs	lb VMs
SFTP	OpenSSH <code>internal-sftp</code> with chroot per tenant	sftp-01
NFS client	<code>nfs-utils</code> , NFSv4.1+, Kerberos or network-isolated export	app, wrk, sftp
Monitoring	Prometheus, Alertmanager, Grafana, <code>node_exporter</code> on every VM, <code>postgres_exporter</code> on db VMs	mon-01 / all
Time	<code>chrony</code> to the bank NTP. Required for correctness, not just tidiness: JWT lifetimes, TOTP codes and session timeouts all depend on clocks agreeing	All VMs
Node.js	Not required on any runtime VM; the shipped console has no build step	—

6.2 Python dependencies (pinned in `requirements.txt`)

FastAPI 0.111, uvicorn 0.30, SQLAlchemy 2.0, pycogp2-binary, Pydantic 2.7, PyJWT (RS256), bcrypt, httpx, Alembic, pyotp, qrcode, signxml and lxml (SAML), NumPy, scikit-learn, joblib, pdfplumber, PyMuPDF, pytesseract, Pillow, and a **CPU-only** PyTorch 2.14 with PyTorch Geometric. The CPU build comes from download.pytorch.org/whl/cpu; a plain PyPI install can pull CUDA wheels many times larger and must be avoided. In a restricted network, build the virtual environment once on a build host with access (or an internal wheel mirror) and ship the finished release directory, rather than installing on each VM.

7. Network requirements

7.1 Zones and addressing

Zone	Members	Inbound from	Outbound to
Edge	lb-01, lb-02 (+ VIPs)	Bank user/server networks; switches	Application zone only
Application	app, dec, wrk, sftp-01	Edge (service ports); sftp from batch senders	Data zone; support; allow-listed egress (\$7.4)
Data	db-01..03, shared storage	Application zone and support only. No inbound from anywhere else. No route out.	Backup repository, DR replication link
Support	mon-01, bank vault/SIEM/SMTP/NTP/DNS	All zones (metrics, logs)	—
Management	Bastion / jump host	Admin workstations (MFA)	SSH to all zones

Reserve a /27 or larger per zone and four VIPs: external service VIP, internal service VIP, database VIP, and (if used) a dedicated ISO 8583 VIP.

7.2 DNS names and certificates

Name (example)	Resolves to	Certificate
<code>fraud360.<bank>.internal</code>	External VIP, gateway pool (console and <code>/api</code>)	Bank internal-CA server certificate, TLS 1.2+ (TLS 1.3 preferred)
<code>decide.fraud360.<bank>.internal</code>	External VIP, decision pool (Lane A <code>/decide</code> only)	Same, as a separate SAN so the path can be policed independently
<code>sftp.fraud360.<bank>.internal</code>	sftp-01	SSH host key; clients pin it
<code>db.fraud360.<bank>.internal</code>	Database VIP (follows the Patroni leader)	Server certificate for <code>sslmode=verify-full</code> if the bank requires TLS to the database
<code>api-int.fraud360.<bank>.internal</code>	Internal service VIP	Optional internal TLS (see §14, gap 3)

`CONSOLE_BASE_URL` must be the exact origin browsers use (the first name above). Federated sign-in redirects the user back to it; if it is wrong, SSO sends users to an internal service address and fails.

7.3 Firewall rule set

#	From	To	Port / protocol	Purpose
1	Bank users, integrators	External VIP	443/tcp	Console, <code>/api</code> , <code>/machine/token</code> , <code>/ingest</code>
2	Core banking / switch (Lane A)	decide VIP	443/tcp	<code>POST /decide</code> with a machine token
3	ISO 8583 switches (if used)	ISO VIP	8583/tcp (LB TCP mode → dec 8588)	Authorisation messages
4	Batch senders	sftp-01	22/tcp	Per-tenant file drop
5	lb VMs	app VMs	8080/tcp	Gateway; health <code>/health/ready</code>
6	lb VMs	dec VMs	8086/tcp	decision-service
7	app, dec, wrk	Internal VIP / each other	8080–8088/tcp	Service-to-service HTTP (<code>INTERNAL_API_KEY</code>), including every authorising service's role lookup against tenant-service on 8081. Plain HTTP today — contain with the zone boundary

#	From	To	Port / protocol	Purpose
8	app, dec, wrk	Database VIP	5432/tcp	SQL, each service as its own role
9	db ↔ db	db-01/02/03	5432, 8008, 2379–2380/tcp	Replication, Patroni REST, etcd
10	app, wrk, sftp-01	Shared storage	2049/tcp (NFSv4)	Statement PDFs, drops, spool
11	mon-01	All VMs	9100/tcp; service ports for /metrics; 9187 on db	Scrape. /metrics requires the internal key header
12	All VMs	NTP, DNS, SIEM, vault	123/udp, 53, 514/6514, 8200 (as applicable)	Bank platform services
13	app (notification)	SMTP relay; allow-listed webhook hosts	25/587/465; 443	Alert and report delivery
14	wrk, app	Egress proxy	443/tcp	Allow-listed external feeds (§7.4)
15	db, sftp-01	Backup repository	per bank backup platform	pgBackRest, snapshots
16	Bastion	All VMs	22/tcp	Administration
17	Everything else	Data zone	Deny	Default deny; no direct client access to PostgreSQL

7.4 Outbound access that needs a decision

The platform makes no outbound call on the transaction path. The following exist on the periphery and must each be allowed, proxied, re-pointed or switched off:

Capability	Destination	What to do on a private cloud
IP geolocation (transaction “Location” panel)	http://ip-api.com/json by default (GEOLOCATE_URL)	That is a free, non-commercial public service: do not rely on it in a bank . Point GEOLOCATE_URL at an internal geolocation service, or leave it unreachable; the panel then reports the location as unavailable and nothing else depends on it.
Reference-list feeds (BR-212) and Lane C feeds	Per-tenant configured URLs (e.g. RBI RSS, MCA/ROC extracts, rating actions)	Allow-list each configured URL through the egress proxy. A fetch that fails, or that returns an empty or much shorter list, is refused and the previous version stays active.
OFAC SDN list	US Treasury public files (SDN.CSV , ALT.CSV)	Allow-list, or stage the files internally and adapt the job. If unreachable the list simply stops refreshing.
SSO	Tenant IdP (OIDC / SAML)	Reachable from tenant-service; usually inside the bank network.
Notification channels	Tenant SMTP relay; webhook targets	Per-tenant; allow-list the relay and hosts.
Local LLM	11m-01 inside the boundary	Only if enabled (§5.6).
Software build	PyPI, download.pytorch.org , OS repositories	Build host only; use internal mirrors. Runtime VMs need no internet.

8. Storage, backup and disaster recovery

8.1 Storage requirements

Data	Where	Protection
Operational and analytical data, documents, audit trail	PostgreSQL (db VMs)	Encrypted volumes; synchronous standby; pgBackRest PITR; encrypted, off-host backups
Statement PDFs, SFTP drops, spool	Shared storage	Encrypted at rest; daily snapshots retained 14 days; replicated to DR
Application releases	<code>/opt/fraud360/releases/<id></code> on each VM	Reproducible from the release artefact; keep the last three on disk
Secrets	Bank vault; rendered to <code>/etc/fraud360/*.env</code> (0600) at start	Custody outside the database, otherwise a stolen backup is self-decrypting (HLD AD-10)
Logs	journald → SIEM; local 14 days	Immutable at the SIEM; the platform also keeps its own audit trail in <code>platform.audit_logs</code>

8.2 Retention

Fraud records are kept for the statutory period; operational data is minimised (NFR-07, BR-713). Retention is an automated job whose default is a dry run: it reports what it would delete using the same predicates as the real purge, and a compliance officer approves the output before `--commit` is used. Backup retention must be at least the longest statutory class plus the restore-test window, and a backup must not outlive a purge indefinitely in a way that defeats data-minimisation — the customer's compliance team sets the period.

8.3 Recovery objectives

Objective	Target (BRD NFR-04/05)	Mechanism	Status
Availability, console	99.5% monthly	Two app VMs behind VRRP load balancers	Design supports
Availability, ingestion	99.9% monthly	Two app VMs + automated database failover; detection backlog is retained, not lost	Design supports; needs measurement
RPO	15 minutes	Continuous WAL archiving; synchronous local standby (zero local loss)	Pending — must be tested (BR-908)
RTO	4 hours	Patroni failover (minutes) for node loss; PITR restore + DR activation for site loss	Pending — must be tested (BR-908)

8.4 Disaster-recovery site

A second Indian site holds a reduced warm copy: db standby (asynchronous, streaming from the primary, pgBackRest repository replicated), one lb, one app, one dec and one wrk VM (about half the primary footprint), and a replica of the shared storage. The standby is promoted by a documented, rehearsed procedure; the DR site is never active against a live primary. Detection workers and timers are not started at DR until promotion.

An untested restore is an assumption

BR-908 is still pending. The acceptance criteria in the Deployment Instructions require a full restore test into a clean environment, and a timed promotion of the standby, before the numbers above are quoted to a regulator.

9. Security and compliance requirements

Area	Requirement
Data localisation	Every VM, volume, snapshot, backup and DR copy in India (REG-07 / BR-714). Verify the object-storage and backup-platform regions explicitly; this is the control most often missed.
Encryption at rest	Volume encryption on the database, WAL, backup repository and shared storage (BR-712). Application-layer AES-256-GCM sealing of MFA seeds, IdP secrets and feed credentials is already built; it needs <code>CP_ENCRYPTION_KEYS</code> set (<code>version:base64-of-32-bytes</code> , comma-separated, highest version used to encrypt). Never set <code>CP_ALLOW_PLAINTEXT_SECRETS</code> in production.
Encryption in transit	TLS 1.2+ at the edge. Database TLS recommended. Service-to-service traffic is plain HTTP inside the application zone today (§14).
Secrets	<code>JWT_SECRET</code> (identical on gateway, tenant, decision and any service that verifies tokens), <code>INTERNAL_API_KEY</code> (identical everywhere), <code>CP_ENCRYPTION_KEYS</code> , eight database passwords, the owner-role password, and the ISO 8583 machine credential held in the bank vault, rotated on policy, delivered as root-owned 0600 environment files. Generate with a CSPRNG; the shipped defaults are published and must never reach production.
Database roles	Services connect only as their own role. <code>provision_db_roles.py</code> applies one password to all eight roles; set a unique password per role immediately afterwards (Deployment Instructions §7.4). The owner password exists only on worker/admin hosts that run migrations and cross-schema jobs.
First-run accounts	<code>SEED_DEMO_TENANT=false</code> . The seeded platform admin is forced to change the published default password at first login; keep <code>SEED_ADMIN_MUST_CHANGE_PASSWORD=true</code> and remove the seed variables after first use.
Authentication	Built: MFA (TOTP), OIDC and SAML SSO, session timeout, refresh tokens, revocation, logout, per-caller rate limiting. Bank decision: enforce SSO and MFA for all human users.
Host hardening	CIS Level 1; SELinux enforcing; key-only SSH through the bastion; no shared accounts; <code>auditd</code> ; unattended security patching in a maintenance window; services run as an unprivileged <code>fraud360</code> account with no login shell.
Edge protection	WAF in front of the external VIP (HLD requirement). The per-IP limit at the load balancer (the repo's reference <code>nginx.conf</code> uses 50 r/s, burst 100) is defence in depth, not a substitute. Do not apply it to the <code>/decide</code> host: a switch legitimately sends from few addresses at high rate.
Audit and logs	journald forwarded to the SIEM. Platform audit events are in the database and included in backups.
Authorisation	What a role may do is data, not code. Each tenant has its own role rows (modules, dashboards, gated actions, and the administer, reveal-customer-data and activate-configuration capabilities), edited by its administrators or by platform staff from the console; every service decides from those rows and nothing falls back to a role list in code. Raising a privilege needs a second person to confirm; lowering one applies on the next request. An edit or delete that would leave a tenant with no administrator who can sign in is refused. The role rows are in the database and therefore in the backups, and the audit trail records every change with before and after. The one exception is the platform operator (Finverge staff), recognised by name in code and not editable by any tenant.
Vendor access	Finverge engineers reach the environment only through the bank's bastion with named, time-boxed accounts. Right-to-audit evidence (BR-910) is produced from this environment.

10. Availability design and failure behaviour

Failure	Effect	Recovery
lb VM lost	VIP moves to the peer in seconds	Automatic (VRRP)
app VM lost	Capacity halves; no outage	LB removes it on failed <code>/health/ready</code> ; replace the VM
One service process dies on an app VM	That VM's gateway readiness fails (it probes its upstreams); the LB drains the whole VM	systemd restarts the process; VM rejoins when ready. Granularity is the VM, not the service
dec VM lost	Remaining VM serves Lane A	Automatic via the internal VIP; N+1 sizing must carry full inline load
All decision capacity lost	Callers get no answer. What the rail does is the bank's policy: <code>RailPolicy.fail</code> (JSON) and <code>ISO8583_FAIL_OPEN</code> (ISO 8583) have no default	Policy must be decided and recorded before go-live (§14)
wrk VM lost	Detection and Lane C slow; queue grows but nothing is lost	wrk-02 continues; enable the scheduled timers on wrk-02 if wrk-01 is down for long
Database primary lost	Writes pause during promotion; pooled connections re-test on use (<code>pool_pre_ping</code>)	Patroni promotes the standby and moves the VIP; expect tens of seconds (to be measured, not promised)
Database logical error or bad deployment	Wrong data, healthy hosts	PITR to just before the event, into a side instance first
Shared storage unavailable	Lane C uploads and parses fail; file drops stall. Lane A, detection and the console are unaffected	Restore the NFS service; senders retry; <code>.done</code> markers prevent half-read files
sftp-01 lost	Batch senders retry	Rebuild from snapshot; data is on shared storage
tenant-service unreachable	Every service refuses requests it must authorise for a tenant whose roles it has not already cached; a service with a cached copy keeps serving the last-known roles and retries. A failed fetch is never recorded as 'this tenant has no roles'	Two app VMs and the internal VIP listener on 8081 keep it available; a role change made during an outage reaches a service once its next fetch succeeds. Fail closed is deliberate
Clock drift	Token and TOTP failures, confusing logs	chrony alerting; fix NTP
Site loss	Primary site unavailable	Promote DR standby per runbook; re-point DNS/VIP; RTO target 4 hours (to be demonstrated)

10.1 Configuration coherence across replicas

Tenant configuration is cached against a shared generation token held in the database, so replicas cannot serve different generations of the same configuration. Set `CACHE_BACKEND=database` and `APP_REPLICAS` to the real replica count on every service; the process-local `memory` backend is refused at startup when `APP_REPLICAS` is greater than one. Leave `CACHE_GENERATION_TTL_SECONDS` at its default of 0; any larger value reopens the divergence window.

11. Observability and operations

Every service exposes `/health/live` (process only), `/health/ready` (dependencies) and `/metrics` (RED metrics, structured access logs). `/metrics` requires the internal key in the request header, so Prometheus needs it as a scrape credential. Distributed tracing and log shipping are not built; an incident is investigated per host, so central log forwarding is a deployment task.

Alert	Condition (starting point)	Why
Pipeline freshness	Age of the oldest unprocessed <code>ingestion.raw_transaction</code> row above 60 s for 5 min	Detection is behind or down; the most important single alert
Decision latency	<code>/decide</code> p99 above the rail budget (150 ms) for 5 min	Lane A is in the payment window
Readiness	Any <code>/health/ready</code> failing for 2 min	VM drained from rotation
5xx rate	Above 1% for 5 min on any service	Service-level fault
Replication lag / failover	Standby lag above 30 s; any leader change	RPO and promotion events
Backup age	No successful full within 8 days; WAL archive gap above 5 min	RPO
Scheduled jobs	Any systemd timer unit in failed state; no run in 2× cadence	Retention, board packs, reference feeds silently stop otherwise
Capacity	Disk above 80%; CPU above 80% for 15 min; DB connections above 70%	Headroom
Certificates	Fewer than 30 days to expiry	Edge outage avoidance
Clock	chrony offset above 1 s	Auth correctness

12. Environments

Environment	Profile	Data	Notes
Production	§5.1	Live	Two-site with DR
DR	§8.4	Replica	Warm; promoted on declaration
UAT / pre-production	§5.2 or half of §5.1 for performance rehearsal	Masked or synthetic	Where the load test and restore test are executed before go-live. Production-like DB storage class
Development / test	Developer workstations or one small VM	Synthetic (<code>generate_synthetic_data.py</code>)	Not hosted on production infrastructure; no production data

13. Prerequisites the customer provides

A single checklist an infrastructure lead can walk. Items are consumed by Deployment Instructions Phase 0.

#	Item	Owner	Done
1	VMs per §5, built from the hardened OS image, with the disk layout stated and encryption applied	Infra	☐
2	VLANs / security groups for the five zones; four VIPs allocated; firewall rules §7.3 implemented	Network	☐
3	DNS names §7.2 and certificates (chain + key) from the internal CA	Network / PKI	☐
4	NTP, DNS, SIEM forwarding and vault access available to all VMs	Infra / Security	☐
5	NFS export (1 TB, NFSv4, encrypted) and the snapshot and replication policy	Storage	☐
6	Backup repository in the same country, in a separate failure domain, with its retention policy	Backup	☐
7	SMTP relay (host, port, credentials) and webhook allow-list	Messaging	☐
8	Egress proxy rules for feeds, OFAC and (build only) package mirrors	Network	☐
9	A bastion and named admin accounts with MFA for the delivery team	Security	☐
10	Vault paths for the secrets in §9; owners and rotation periods agreed	Security	☐
11	Tenant IdP details (OIDC discovery URL / SAML metadata), if SSO is in scope	IAM	☐
12	Decision: Lane A fail-open or fail-closed per rail; ISO 8583 in or out of scope	Business / Risk	☐
13	Expected peak tps per tenant, tenant count, retention classes	Business	☐
14	Change window and DR-test dates	Programme	☐

14. Known gaps and risks

Stated plainly so none of them is discovered at go-live. Each has a mitigation inside this design; none is hidden.

#	Gap	Consequence	Mitigation / owner
1	The repository's <code>docker-compose.yml</code> and Kubernetes manifests trail the current service set (compose has five services; the ingestion, decision, notification, Lane C and ISO 8583 services are missing; one k8s manifest exists, for analytics only)	They cannot be used as the production definition	This design does not use them; systemd units are specified in the Deployment Instructions. Finverge to refresh the container assets if a container platform is later chosen
2	Capacity is not evidenced beyond one detection worker (BR-909)	Sizing is an estimate	Mandatory load test at acceptance (Deployment Instructions §15.1); revise §5
3	Service-to-service traffic is plain HTTP, authenticated by a shared internal key; mTLS is not built	A compromised host in the application zone can speak to peers	Zone isolation, host firewalls, key rotation; optional TLS on the internal VIP; Finverge roadmap item
4	<code>provision_db_roles.py</code> sets one password for all eight roles	Isolation by privilege is real, but credentials are shared until changed	Per-role <code>ALTER ROLE ... PASSWORD</code> immediately after (Deployment Instructions §7.4); script enhancement requested
5	No distributed tracing or log shipping	Investigations are per host	Forward journald to the SIEM; central dashboards from <code>/metrics</code>
6	Backup, restore and DR are not yet exercised (BR-908)	RPO/RTO are targets, not evidence	Acceptance criteria require both tests
7	Gateway rate limiting is per process	Effective ceiling is N× the setting	Intended; use load-balancer per-IP limits and the WAF for hard limits
8	Readiness drains a whole app VM when any local service fails	Capacity drops by half for a single-service fault	Fast systemd restarts; add a third app VM if 50% is unacceptable
9	Default geolocation provider is a public free service	Panel unavailable, or worse, an unapproved outbound call	§7.4: re-point or leave blocked
10	Tenants share one database (logical isolation)	A customer requiring physical separation between entities needs separate installations	Deploy per entity; sizes in §5 apply per installation
11	ISO 8583 gateway is proposal-stage and has no safe default for "no answer"	A bank could silently choose approve-all or decline-all	Explicit written decision before enablement (§13, item 12)
12	Authorisation depends on tenant-service being reachable from every service (including worker and decision VMs through the internal VIP)	A tenant-service outage, or a missing <code>TENANT_SERVICE_URL</code> , shows as <code>role_not_permitted</code> for everyone with no cached copy	Monitor tenant-service readiness; keep two app VMs; include the role lookup in the acceptance tests (Deployment Instructions §15)
13	The platform operator (<code>platform_admin</code>) is the one role recognised by name in code; platform staff are not a tenant role	Its authority is a deployment-level control, not a table a tenant can edit	Intended; a separate platform-roles table is a possible later change
14	Two of 42 RBI signals (#38, #39) remain deliberately partial: they depend on the optional local-LLM read	Not an infrastructure gap; LLM host sizing in §5.6 applies only if enabled	Customer opt-in

Appendix A — If the React console is hosted later

The baseline console is the static SPA served by the gateway. The newer React console in `frontend/` builds with `npm run build` (TypeScript build plus Vite) and talks to the same `/api` surface. It is not currently served by the gateway. To host it, add a build step on the build host (Node 20 LTS), publish `dist/` to the lb VMs, serve it from a small static web server on the lb VMs (or an HAProxy backend) at `/`, and route `/api/` to the gateway pool. Check its base path and API prefix against the gateway routes before cutover, and keep the shipped console available as a fallback until the migration is complete. No additional VMs are needed.

Appendix B — Decisions requested from the customer

#	Decision	Default if not decided
1	Hypervisor and OS (A1, A2)	Linux x86-64, RHEL-family 9
2	Availability tier: full production profile (§5.1) or pilot (§5.2)	Pilot for UAT, full profile for production
3	Lane A inline and ISO 8583 in scope?	Lane A yes; ISO 8583 no
4	Fail-open or fail-closed per rail	None — must be decided
5	Local LLM features (narrative polish, Lane C qualitative read, AI Insights)	Off
6	SSO provider and MFA enforcement	Local accounts with TOTP MFA
7	Expected peak tps, tenant count, hot-data window	Mid-sized assumption in A10
8	Statutory retention classes and backup retention	Customer compliance to state
9	DR site location and DR-test cadence	Second Indian site; twice-yearly test
10	Separate installation per entity, or one multi-tenant installation	One multi-tenant installation